

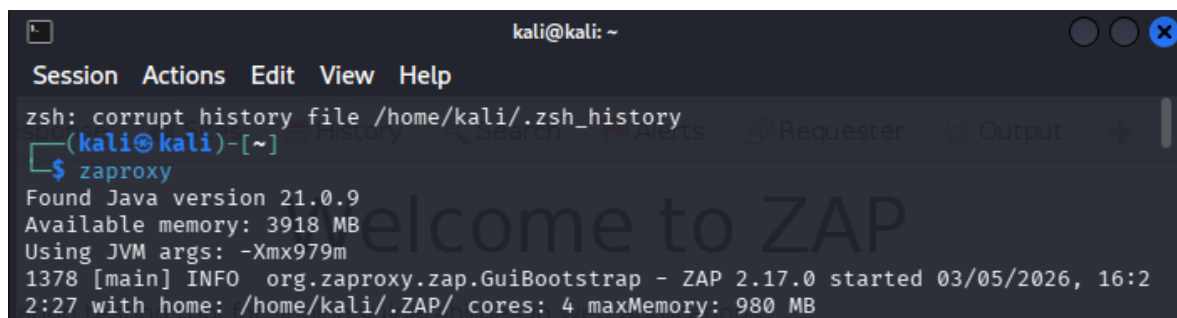
Pruebas a la página oficial de Colombia Comparte

Con ZAP (Zap Proxy)

Para hacer las pruebas respectivas sobre la seguridad de la página de Colombia Comparte vamos a realizarlas en una máquina virtual de Kali Linux, en esta guía explicaremos paso a paso el uso de la herramienta para la replicación de las pruebas por parte de cualquier persona y la interpretación de los resultados.

1. Verificación OWASP ZAP en Kali Linux

Buscamos “zapproxy”



```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ zapproxy  
Found Java version 21.0.9  
Available memory: 3918 MB  
Using JVM args: -Xmx979m  
1378 [main] INFO org.zaproxy.zap.GuiBootstrap - ZAP 2.17.0 started 03/05/2026, 16:22:27 with home: /home/kali/.ZAP/ cores: 4 maxMemory: 980 MB
```

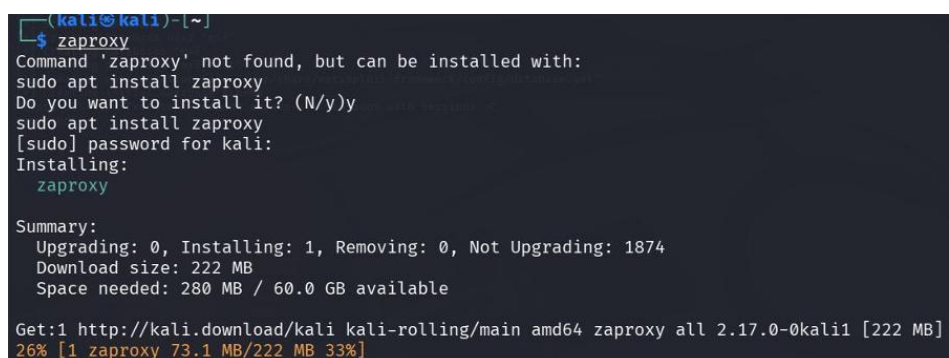
En caso de no encontrarse instalado de base proceda al paso 2

2. Instalar manualmente

Pegamos los siguientes comandos:

`sudo apt update`

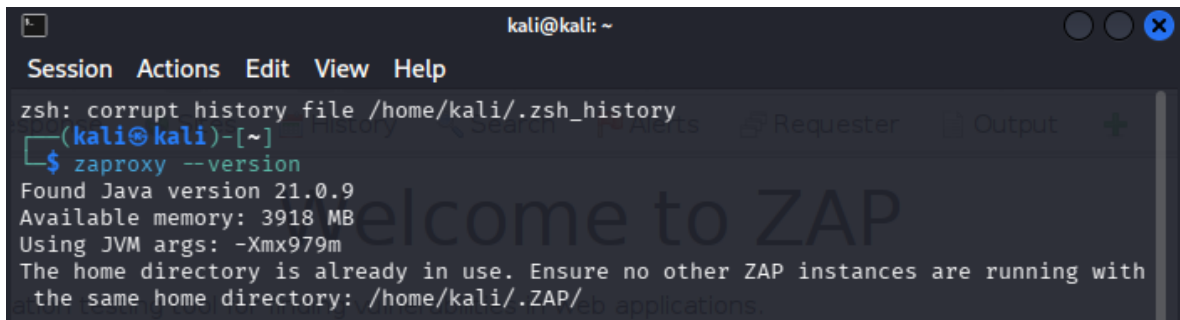
`sudo apt install zapproxy -y`



```
(kali@kali)-[~]  
$ zapproxy  
Command 'zapproxy' not found, but can be installed with:  
sudo apt install zapproxy  
Do you want to install it? (N/y)y  
[sudo] password for kali:  
Installing:  
zapproxy  
Summary:  
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1874  
Download size: 222 MB  
Space needed: 280 MB / 60.0 GB available  
Get:1 http://kali.download/kali kali-rolling/main amd64 zapproxy all 2.17.0-0kali1 [222 MB]  
26% [1 zapproxy 73.1 MB/222 MB 33%]
```

3.Verificamos su instalación con:

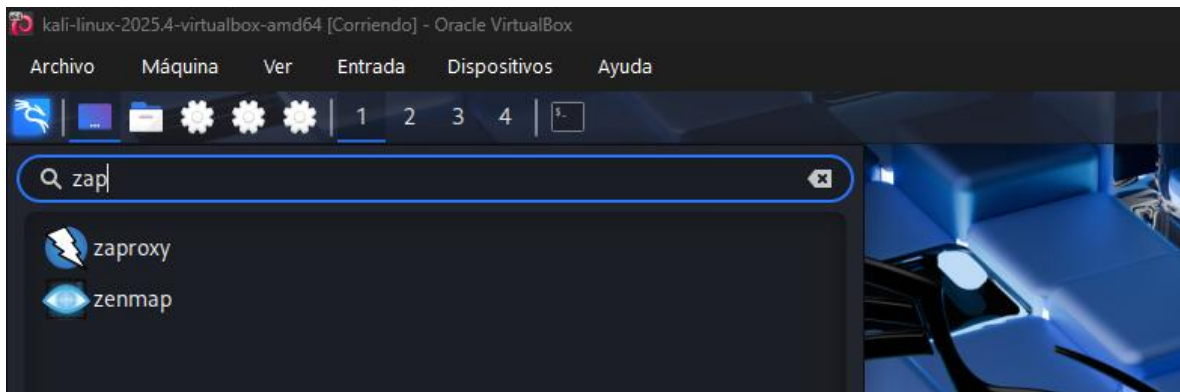
zaproxy --version



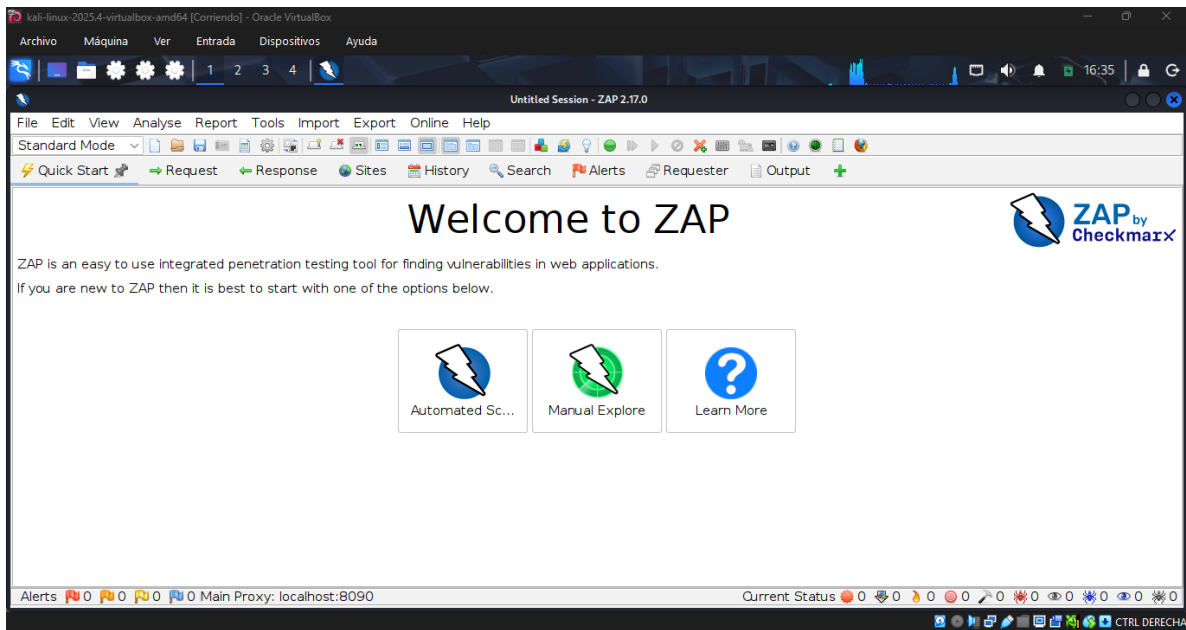
```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ zaproxy --version  
Found Java version 21.0.9  
Available memory: 3918 MB  
Using JVM args: -Xmx979m  
The home directory is already in use. Ensure no other ZAP instances are running with  
the same home directory: /home/kali/.ZAP/
```

4. Abrir OWASP ZAP

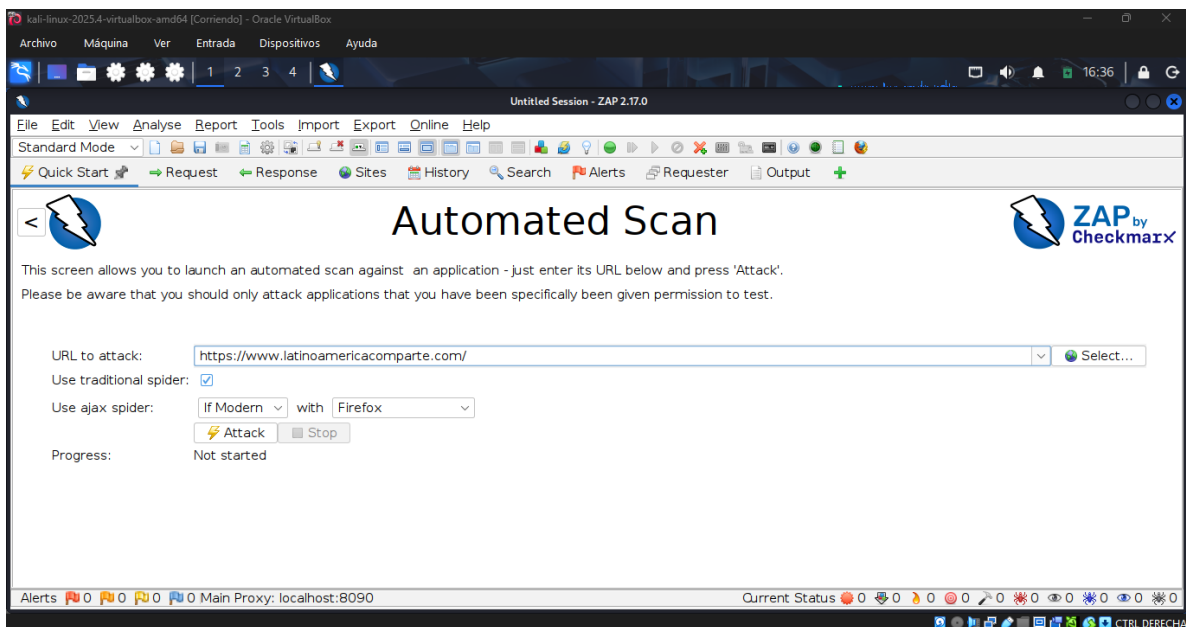
Buscamos en la palabra “Zap” en el buscador y abrimos



5.Ingresamos a la interfaz de OWASP ZAP

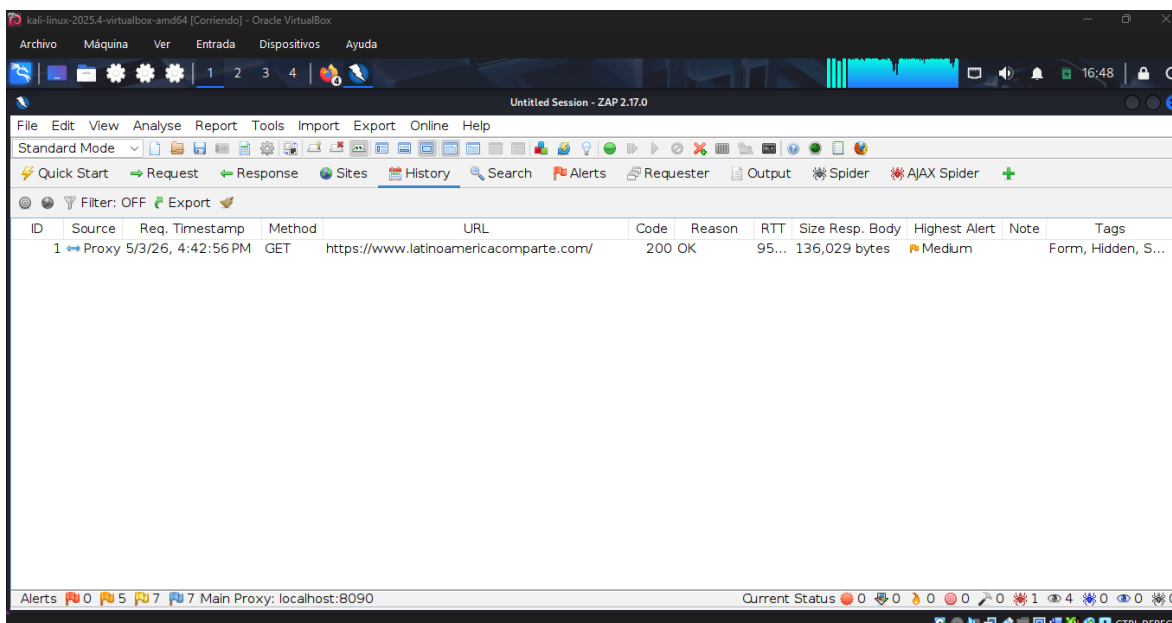


6. Ingresamos en la opción de Automated Scan y pegamos la URL del sitio y damos a la opción de Attack

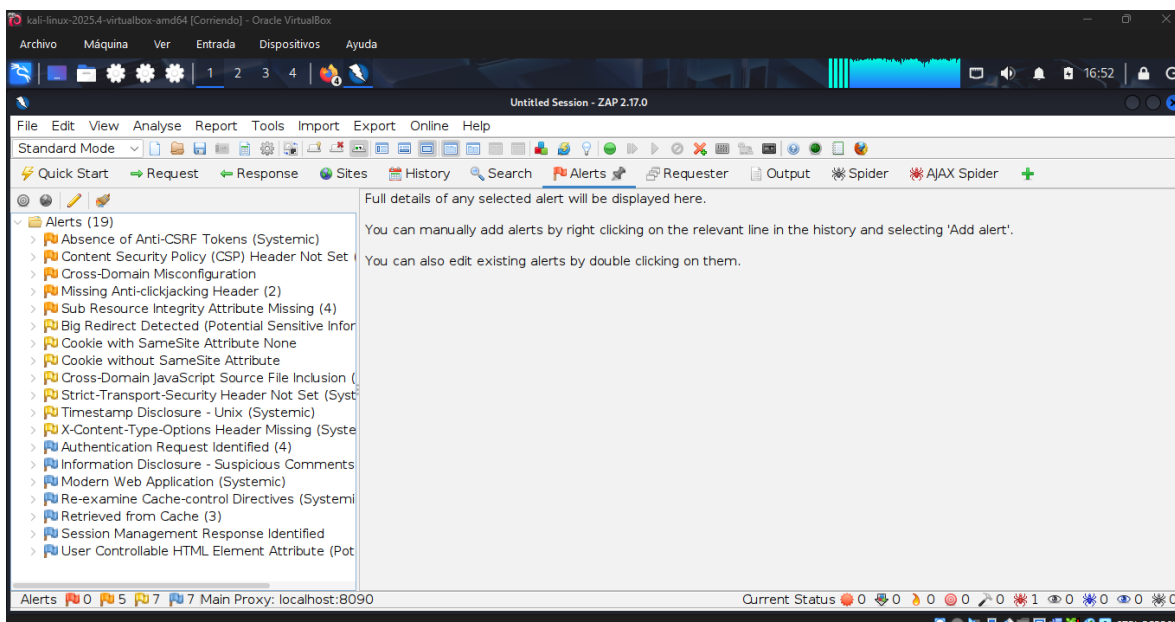


En los siguientes pasos miraremos la diferente información que nos brinda la página sobre el sitio de Colombia comparte, analizaremos las entradas más relevantes y explicaremos las mismas. Aclaremos que Zap va a abrir la página dentro del navegador que se dejó de predeterminado en el escaneo, cosa totalmente normal.

7. En el apartado de “History” podremos ver toda las URL que hacemos prueba y lo más importante arriba a la derecha un resumen del nivel de vulnerabilidades que es Media.



8.En el apartado de “Alerts” profundizaremos más sobre las diferentes vulnerabilidades que presenta la página.



Algunas vulnerabilidades son detalles que se deberían tratar dependiendo ya de la severidad y frecuencia dentro del sitio. Las banderas naranjas indican prioridades inmediatas, ya que pueden comprometer directamente la integridad de los datos de tus usuarios como:

Absence of Anti-CSRF Tokens: El sitio permite realizar acciones como cambiar una contraseña o hacer una compra sin verificar que la petición fue iniciada intencionalmente por el usuario. Su Importancia recae en que un atacante podría engañar a un usuario autenticado para que haga clic en un enlace malicioso que ejecute acciones en su nombre dentro de tu web sin que se dé cuenta.

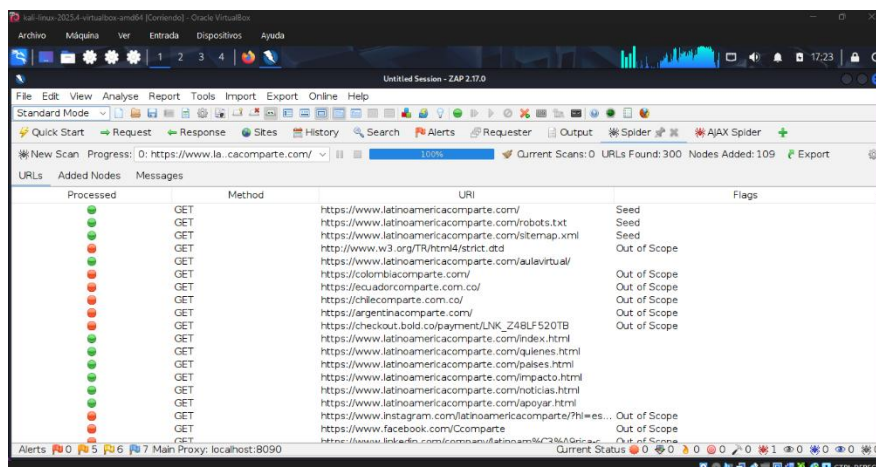
Content Security Policy (CSP) Header Not Set: Falta una capa de seguridad que indica al navegador qué fuentes de contenido (scripts, imágenes, etc.) son de confianza. Sin CSP, es mucho más fácil para un atacante inyectar scripts maliciosos (Cross-Site Scripting - XSS) para robar cookies de sesión o redirigir a los usuarios.

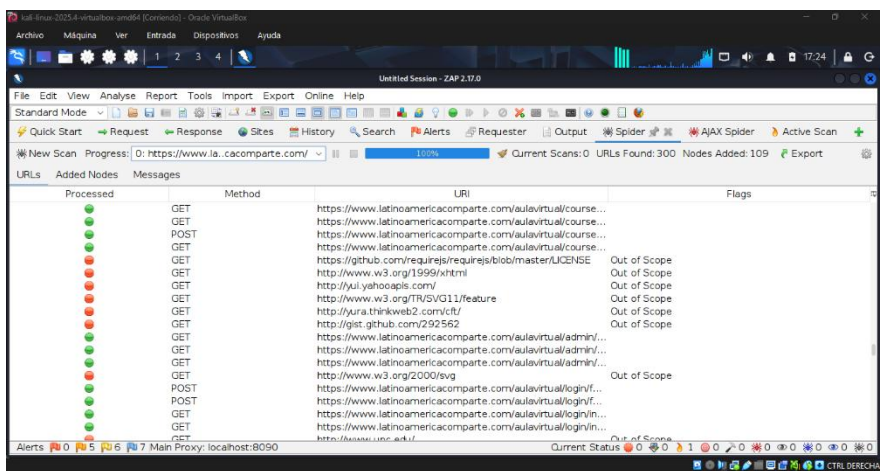
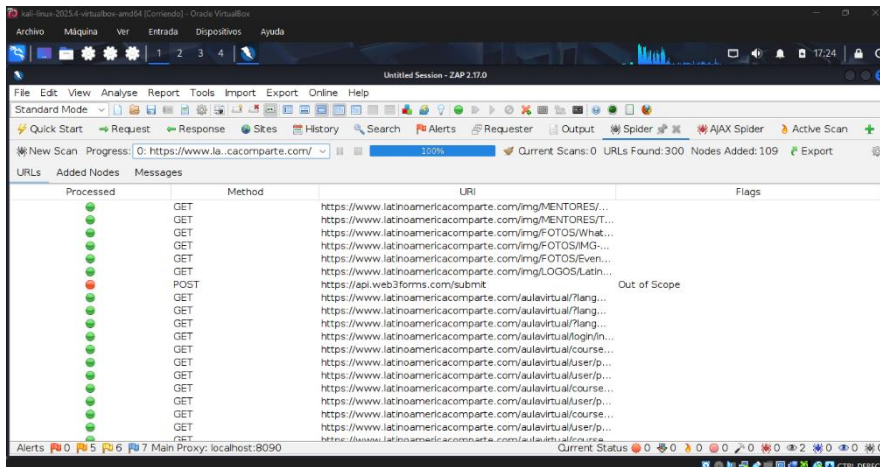
Missing Anti-clickjacking Header: La página no prohíbe ser cargada dentro de un <iframe> en otro sitio. Un atacante puede copiar tu página de forma invisible sobre la suya para engañar al usuario y que haga clic en botones que no ve, por ejemplo, un botón de "Borrar Cuenta" camuflado bajo un juego.

Ya por último indicamos que las banderas amarillas indican que suelen facilitar ataques más complejos o exponen información técnica y las azules no son vulnerabilidades como tal, pero son pistas valiosas para un auditor o un atacante.

9. Analizamos Spider (Reconocimiento de rutas URL)

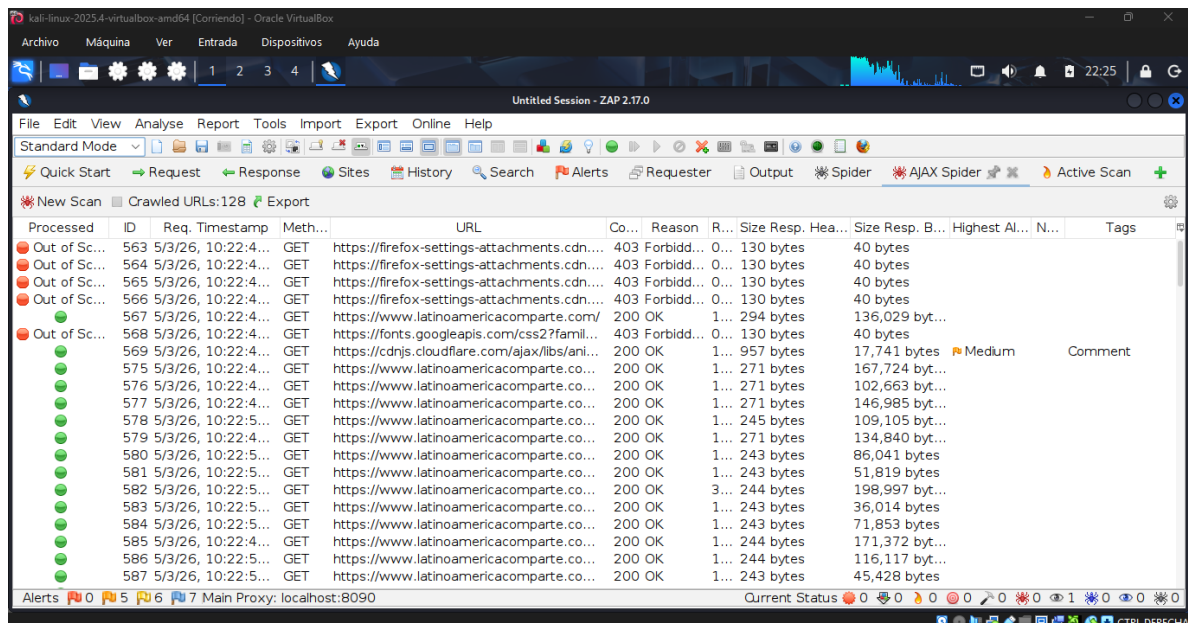
El análisis revela una superficie de ataque significativa centrada en el componente /aulavirtual/, donde el Spider ha identificado múltiples vectores de entrada mediante métodos POST y rutas administrativas expuestas como /admin/. La presencia de vulnerabilidades de riesgo alto anteriormente mencionadas, como la ausencia de tokens Anti-CSRF y la falta de una Política de Seguridad de Contenido (CSP), sugiere que la plataforma es susceptible a ataques de suplantación de identidad e inyección de scripts maliciosos.



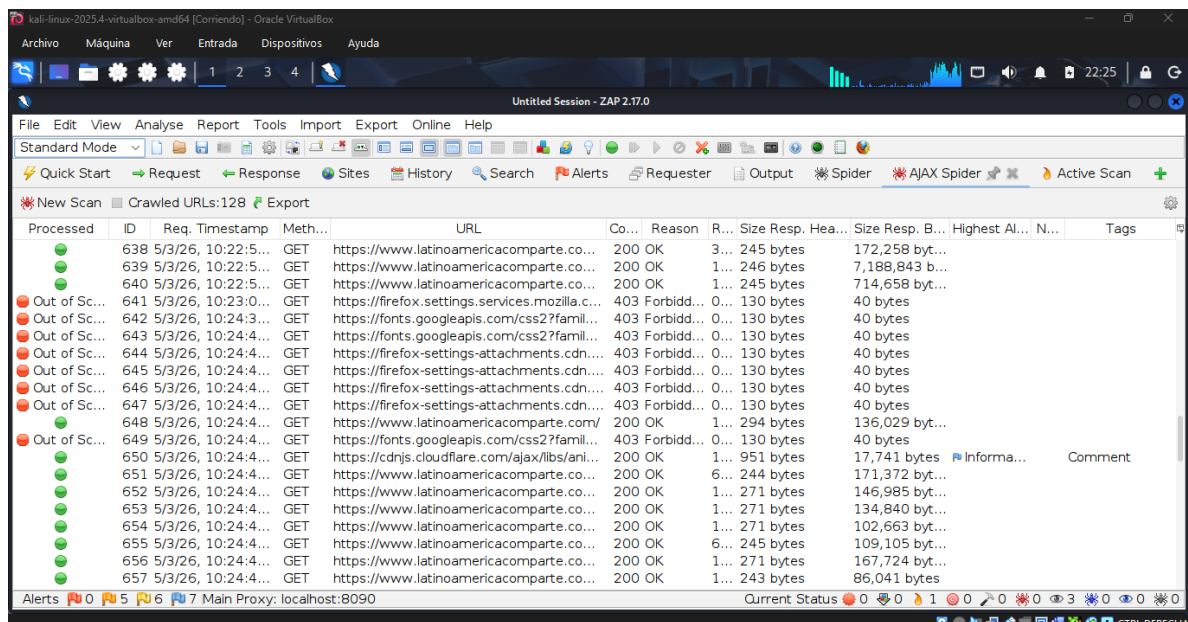


Este mapeo inicial, que incluye el descubrimiento de 300 URLs y la exposición de directorios de imágenes y archivos de configuración como robots.txt, resalta la importancia de asegurar los puntos de gestión de sesiones y restringir el acceso a rutas sensibles para proteger la integridad de los datos de los usuarios.

10. Ajax Spider(Simulación de navegación por el sitio)

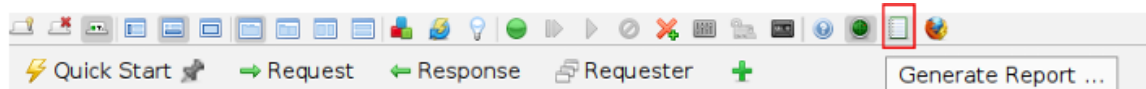


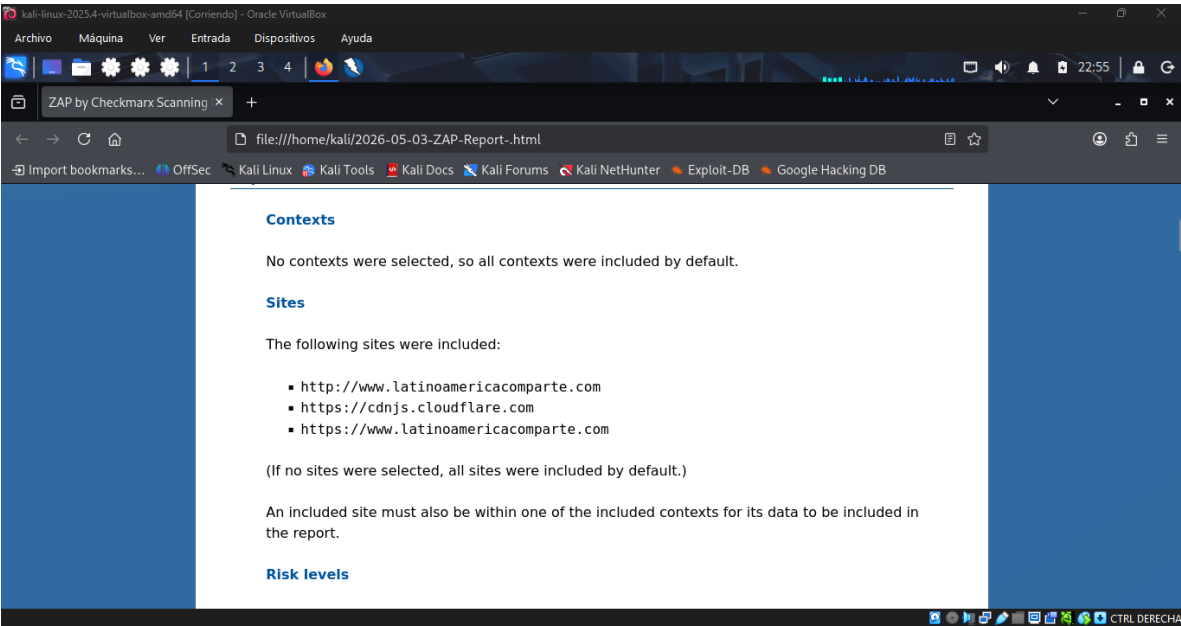
Processed	ID	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. Hea...	Size Resp. B...	Highest Al...	N...	Tags
Out of Sc...	563	5/3/26, 10:22:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	564	5/3/26, 10:22:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	565	5/3/26, 10:22:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	566	5/3/26, 10:22:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
	567	5/3/26, 10:22:4...	GET	https://www.latinamericacomparte.com/	200	OK	1...	294 bytes	136,029 byt...			
Out of Sc...	568	5/3/26, 10:22:4...	GET	https://fonts.googleapis.com/css2?famil...	403	Forbidd...	0...	130 bytes	40 bytes			
	569	5/3/26, 10:22:4...	GET	https://cdnjs.cloudflare.com/ajax/libs/ani...	200	OK	1...	957 bytes	17,741 bytes	Medium		Comment
	575	5/3/26, 10:22:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	167,724 byt...			
	576	5/3/26, 10:22:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	102,663 byt...			
	577	5/3/26, 10:22:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	146,985 byt...			
	578	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	245 bytes	109,105 byt...			
	579	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	134,840 byt...			
	580	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	86,041 bytes			
	581	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	51,819 bytes			
	582	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	3...	244 bytes	198,997 byt...			
	583	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	36,014 bytes			
	584	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	71,853 bytes			
	585	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	244 bytes	171,372 byt...			
	586	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	244 bytes	116,117 byt...			
	587	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	45,428 bytes			



Processed	ID	Req. Timestamp	Meth...	URL	Co...	Reason	R...	Size Resp. Hea...	Size Resp. B...	Highest Al...	N...	Tags
	638	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	3...	245 bytes	172,258 byt...			
	639	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	246 bytes	7,188,843 b...			
	640	5/3/26, 10:22:5...	GET	https://www.latinamericacomparte.co...	200	OK	1...	245 bytes	714,658 byt...			
Out of Sc...	641	5/3/26, 10:23:0...	GET	https://firefox.settings.services.mozilla.c...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	642	5/3/26, 10:24:3...	GET	https://fonts.googleapis.com/css2?famil...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	643	5/3/26, 10:24:4...	GET	https://fonts.googleapis.com/css2?famil...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	644	5/3/26, 10:24:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	645	5/3/26, 10:24:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	646	5/3/26, 10:24:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
Out of Sc...	647	5/3/26, 10:24:4...	GET	https://firefox-settings-attachments.cdn...	403	Forbidd...	0...	130 bytes	40 bytes			
	648	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.com/	200	OK	1...	294 bytes	136,029 byt...			
Out of Sc...	649	5/3/26, 10:24:4...	GET	https://fonts.googleapis.com/css2?famil...	403	Forbidd...	0...	130 bytes	40 bytes			
	650	5/3/26, 10:24:4...	GET	https://cdnjs.cloudflare.com/ajax/libs/ani...	200	OK	1...	951 bytes	17,741 bytes	Informa...		Comment
	651	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	6...	244 bytes	171,372 byt...			
	652	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	146,985 byt...			
	653	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	134,840 byt...			
	654	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	102,663 byt...			
	655	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	6...	245 bytes	109,105 byt...			
	656	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	271 bytes	167,724 byt...			
	657	5/3/26, 10:24:4...	GET	https://www.latinamericacomparte.co...	200	OK	1...	243 bytes	86,041 bytes			

El uso del **AJAX Spider** confirmó que la aplicación tiene una carga dinámica de recursos y depende de APIs externas como Google, Cloudflare. Aunque la mayoría de las peticiones devolvieron un estado 200 OK, se identificaron respuestas inusualmente pesadas que podrían afectar el rendimiento o indicar exposición de datos, además de detectarse comentarios sospechosos en scripts de terceros que requieren una revisión manual detallada.





Risk levels

		Confidence			
		User Confirmed	High	Medium	Low
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	2 (10.5%)	2 (10.5%)	1 (5.3%)
	Low	0 (0.0%)	1 (5.3%)	5 (26.3%)	1 (5.3%)
	Informational	0 (0.0%)	1 (5.3%)	3 (15.8%)	3 (15.8%)
	Total	0 (0.0%)	4 (21.1%)	10 (52.6%)	5 (26.3%)

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://www.latinoamericacomparte.com	0 (0)	0 (0)	1 (1)	0 (1)
	https://cdnjs.cloudflare.com	0 (0)	1 (1)	0 (1)	1 (2)
	https://www.latinoamericacomparte.com	0 (0)	4 (4)	6 (10)	6 (16)

Alert Counts by Alert Type

El análisis final de vulnerabilidades identifica un total de 19 alertas, destacando 5 vulnerabilidades de riesgo medio que comprometen la integridad de las sesiones de usuario y la ejecución de scripts. La falta de tokens Anti-CSRF y de una política CSP robusta representan el mayor peligro, permitiendo ataques de suplantación e inyección. Se recomienda priorizar la implementación de cabeceras de seguridad y la validación de integridad en recursos externos (SRI) para mitigar el riesgo de compromiso a través de terceros y asegurar el portal de Aula Virtual identificado durante el mapeo.